

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

Risk Vulnerability Scanning Procedure (RA-5)

Risk Vulnerability Scanning Procedure (RA-5)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 2

6.0. Coordination Among Agency Entities 2

7.0. Compliance 2

8.0. Procedures 3

9.0. Document Details 9

10.0. Review 9

11.0. Records Management 10

12.0. Public Records Exceptions 10

13.0. Definitions 10

14.0. Abbreviations 11

Risk Vulnerability Scanning Procedure (RA-5)

1.0. Document Purpose

The purpose of this document is to define the Office of Information Technology's (OIT's) procedures for assessing cybersecurity vulnerabilities through proactive scanning of information assets (see Definitions) and addressing vulnerabilities in a timely fashion. It falls under the umbrella Risk Assessment Policy. More specifically, this document corresponds to Control RA-5, Vulnerability Monitoring and Scanning, including enhancements RA-5(2) through RA-5(6), RA-5(8), RA-5(10), and RA-5(11) of the National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1].

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Policy Conflict

If this policy conflicts with any applicable law or union contract, the terms of the existing law or contract shall prevail.

4.0. Roles and Responsibilities

Please refer to the Risk Assessment (RA) Policy and Procedures[2] document.

5.0. Management Commitment

The State of Maine is committed to following this policy and the procedures that support it.

6.0. Coordination Among Agency Entities

Please refer to the Risk Assessment (RA) Policy and Procedures[3] document.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

---

1 https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RiskAssessmentPolicyProcedure.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/RiskAssessmentPolicyProcedure.pdf

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine vulnerability scanning processes.

8.1. For OIT-hosted information assets, OIT Information Security executes the vulnerability (see Definitions) scans.

8.2. For externally hosted information assets (see Definitions), OIT Information Security either executes the vulnerability scans or collects vulnerability scans from vendors or other third-party auditors.

8.3. OIT Information Security distributes the scan results, on a need-to-know basis, to the downstream partners and works with them to filter out the false positives and false negatives, thereby identifying the legitimate vulnerabilities (see Definitions). The downstream partners and information asset owners include:

8.3.1. OIT Client Technologies;

8.3.2. OIT Network Services;

8.3.3. OIT Computing Infrastructure and Services;

8.3.4. OIT Data Services; and

8.3.5. OIT Application Divisions.

8.4. The downstream partners listed above remediate all legitimate vulnerabilities within their span of control (see Definitions), within the prescribed remediation schedule. They also collaborate with OIT Information Security in exploring compensating controls (see Definitions) should outright remediation turn out to be elusive.

8.5. OIT Information Security also liaises with horizontal industry partners (see Definitions), on a need-to-know basis, to help contain similar vulnerabilities in the wild. These include the Multi-State Information Sharing & Analysis Center (MS-ISAC)[4] and the Maine Information and Analysis Center (MIAC),[5] (which interfaces with State, local, and Federal law-enforcement partners).

8.6. DAFS IT Procurement, in collaboration with agency business partners and OIT information asset owners, holds all vendors and partners for externally hosted information assets accountable to this procedure, within the vendor's or partner's span of control.

[4] https://www.cisecurity.org/ms-isac/
[5] https://memiac.org/

8.7. OIT Account Managers own the agency business customer interface related to this Procedure.

8.8. Vulnerability Risk Classification:

8.8.1 Vulnerability scanners (see Definitions) provide an initial assessment of vulnerability severity using vendor-defined scoring methodologies (e.g., CVSS). OIT Information Security, under the designation of the Chief Information Security Officer (CISO) or designee, shall evaluate identified vulnerabilities using a risk-based prioritization methodology that considers vulnerability severity in conjunction with additional enterprise risk factors. These factors include, but are not limited to:

8.8.1.1. Known Exploited Vulnerability (KEV) status or evidence of active exploitation;

8.8.1.2. Internet or external exposure of the affected asset;

8.8.1.3. Asset criticality and business function;

8.8.1.4. Sensitivity and classification of data processed or stored;

8.8.1.5. Exploit availability and ease of exploitation;

8.8.1.6. Existing compensating or mitigating security controls;

8.8.1.7. Threat intelligence and current attack activity; and

8.8.1.8. Potential operational, financial, legal, or reputational impact.

8.8.2. Based on this evaluation, OIT Information Security shall assign each vulnerability to one of the following enterprise risk tiers:

8.8.2.1. Critical: A vulnerability presenting an unacceptable level of enterprise risk due to active exploitation, inclusion in the CISA Known Exploited Vulnerabilities (KEV) Catalog, public exposure, or potential to significantly disrupt critical business operations or compromise sensitive information.

8.8.2.2. High: A vulnerability presenting a significant risk to the confidentiality, integrity, or availability of State information assets and requiring prompt remediation based on exploitability, asset criticality, or business impact.

8.8.2.3. Medium: A vulnerability presenting a measurable but manageable level of risk that should be remediated through planned corrective actions consistent with organizational priorities.

8.8.2.4. Low: A vulnerability presenting minimal enterprise risk that may be addressed through routine maintenance, product lifecycle upgrades, or other planned operational activities.

8.9. Vulnerability Remediation:

8.9.1. Remediation priorities shall be based on enterprise risk rather than vulnerability severity alone. OIT Information Security may adjust remediation priorities based on changes in threat intelligence, active exploitation, business criticality, operational requirements, or organizational risk tolerance.

8.9.2. For *new* information assets:

8.9.2.1. Vulnerabilities classified as Critical, High, or Medium shall be remediated, mitigated, or formally accepted through the established risk acceptance process prior to production deployment.

8.9.2.2. Low-risk vulnerabilities must be remediated in alignment with the natural product lifecycle (version and release upgrades, patch lifecycle, and so on).

8.9.3. For *established* information assets:

8.9.3.1. Critical-risk vulnerabilities shall be remediated or mitigated as soon as operationally feasible and no later than fifteen (15) calendar days from identification unless a shorter timeframe is established by OIT Information Security due to active exploitation or other elevated risk factors.

8.9.3.2. High-risk vulnerabilities shall be remediated within thirty (30) calendar days of identification.

8.9.3.3. Medium-risk vulnerabilities shall be remediated within ninety (90) calendar days of identification.

8.9.3.4. Low-risk vulnerabilities shall be remediated in accordance with the natural product lifecycle, scheduled maintenance windows, or documented risk treatment plans.

8.9.4 Where remediation cannot be completed within the prescribed timeframe, the system owner shall document the business justification, compensating controls, residual risk, planned remediation date, and obtain formal risk acceptance in accordance with State risk management procedures.

8.9.5 Typically, vulnerabilities are remediated by applying vendor-supplied patches or updating custom code. However, under certain circumstances, compensating controls may be used as an alternative until the next maintenance/patching schedule. The CISO remains the final arbiter of whether a compensating control qualifies as remediation and the timeframe for such remediation.

8.10. Risk Reclassification and Exception Authority:

8.10.1. Irrespective of the initial risk classification or default remediation schedule, the Chief Information Security Officer (CISO), or designee, in consultation with the Co-Chairs of the Change Advisory Board, may modify the risk classification, remediation priority, or remediation timeframe based on enterprise risk considerations, including but not limited to emerging threat intelligence, active exploitation, asset criticality, regulatory obligations, mission impact, or organizational risk tolerance.

8.10.2. When necessary to address an identified cybersecurity risk, the CISO, or designee, in consultation with the Co-Chairs of the Change Advisory Board, may authorize remediation outside established change management processes or schedules. In such circumstances, affected agencies shall be notified as soon as practicable of the remediation activity and any known or anticipated operational impact. Agency notification does not constitute an approval requirement for remediation determined necessary to protect State information systems, data, or services.

8.11. Exception and Escalation

8.11.1. When remediation or an effective compensating mitigation cannot be completed within the applicable timeframe, the requester shall initiate the emergency waiver request process defined in Section 5.2 of the organization's Waiver Policy[6] before the remediation deadline. The request shall document the reason remediation cannot occur, the associated residual risk, interim safeguards, the accountable owner, and the proposed date for permanent remediation; a waiver is not effective until formally approved and does not supersede any binding legal, regulatory, or CISA requirement.

8.11.2. Approved exceptions shall be time-limited, reviewed at intervals defined in the approved waiver, and reassessed whenever threat intelligence, asset exposure, exploitability, vendor guidance, or operational conditions change. Exception approval constitutes documented acceptance of residual organizational risk but does not waive, supersede, or extend a deadline imposed by law, regulation, CISA directive, emergency directive, or other binding authority.

8.12. Vendor-controlled Technologies

8.12.1. Requirements governing supplier security obligations, contract language, acquisition and renewal decisions, vendor performance, and product or service replacement are addressed in the organization's

[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/Waiver.pdf

System and Services Acquisition Policy[7]. System owners, procurement personnel, and contracting officials shall follow that policy when acquiring, renewing, modifying, or replacing technologies subject to vulnerability-management requirements.

8.13. The vulnerability scanners are updated in real-time as they are released by the vendor. **(RA-5(2))**

8.14. The vulnerability scanners utilized by OIT are industry-leading products, and, at a minimum, they are configured for **(RA-5(3), RA-5(4))**:

8.14.1. The CIS Benchmarks for Configurations[8];

8.14.2. Missing original vendor patches;

8.14.3. Missing third-party, commodity application (such as from Adobe, Oracle-Java, and others) patches;

8.14.4. Misconfigurations in third-party commodity applications (such as from Adobe, Oracle-Java, and others), as recommended by the product vendors or industry partners;

8.14.5. Functions, services, ports, and protocols that should be disabled or restricted, as recommended by the product vendors or industry partners;

8.14.6. Higher sensitivity toward information assets that are discoverable from the internet;

8.14.7. Higher sensitivity toward the potential for privilege escalation;

8.14.8. Higher sensitivity toward the potential for information leakage;

8.14.9. Industry-standard output, in terms of the Common Vulnerabilities and Exposures (CVE),[9] the Open Vulnerability and Assessment Language (OVAL),[10] the Common Weakness Enumeration (CWE),[11] the National Vulnerability Database (NVD),[12] the Common Vulnerability Scoring System (CVSS),[13] and others;

8.14.10. For web-based applications, vulnerability standards include the Open Web Application Security Project (OWASP),[14] SAFECode,[15] Building

[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemAndServicesAcquisitionPolicy.pdf
[8] https://www.cisecurity.org/cis-benchmarks/
[9] https://cve.mitre.org/
[10] https://oval.mitre.org/
[11] https://cwe.mitre.org/
[12] https://nvd.nist.gov/
[13] https://www.first.org/cvss/
[14] https://www.owasp.org/
[15] https://safecode.org/

Security in Maturity Model (BSIMM),[16] the Cloud Security Alliance,[17] and so on.

8.15. At a minimum, the vulnerability scans are authenticated (white-box) scans using administrative/privileged access. **(RA-5(5))**

8.16. Scanning Frequency:

8.16.1. OIT-hosted infrastructure is scanned at Infrastructure Deployment Certification,[18] when new vulnerabilities potentially affecting such information assets are reported by industry partners, and whenever a major upgrade to such an information asset is performed. Additionally:

8.16.1.1. Servers (including server-based backup components) and databases are scanned at least once per month.

8.16.1.2. Perimeter firewalls are scanned routinely by the U.S. Department of Homeland Security, which also provides weekly reports of these scans.

8.16.1.3. Endpoint workstations undergo local vulnerability scans once every six hours.

8.16.1.3.1. Ad Hoc reviews of Microsoft Defender reports are compared to vulnerability scans for comparison purposes.

8.16.1.4. Endpoint mobile devices are managed via a mobile endpoint security application.

8.16.2. OIT-hosted applications are scanned at Application Deployment Certification[19] and as requested.

8.16.3. Externally hosted information assets are scanned at the relevant Deployment Certification (infrastructure or application) and once every calendar year subsequently. They are also scanned at every major upgrade, and when new vulnerabilities potentially affecting such information assets are reported by industry partners. Depending on the contractual terms, OIT Information Security may do the scanning, a scan may be provided by the vendor, or a third-party auditor may provide the scan.

8.17. Any vulnerability remediation (including instituting compensating controls) on any information asset involves testing, and it potentially impacts agency business partners. OIT must coordinate all agency business partners through the Account

[16] https://www.bsimm.com/
[17] https://cloudsecurityalliance.org/
[18] https://www.maine.gov/oit/policies/Infrastructure-Deployment-Certification.pdf
[19] https://www.maine.gov/oit/policies/Application-Deployment-Certification.pdf

Managers. Agencies cooperate with OIT on User Acceptance Testing for the remediation of legitimate vulnerabilities.

8.18. To support responsible vulnerability disclosure, OIT maintains a public reporting channel for independent researchers and external parties. Vulnerabilities may be reported to the Security Operations Center (SOC) via MaineITSecurityOperations@maine.gov. This channel is publicly discoverable and includes language authorizing good-faith research and disclosure. While OIT may request a defined remediation window, it does not condition authorization on indefinite non-disclosure. **RA-5(11)**

8.19. Any necessary configuration change must be managed as outlined in the Change Management Policy.[20]

8.20. OIT employs an industry-leading security information and event management (SIEM) system, to:

8.20.1. Compare the results of vulnerability scans over time to determine trends in information system vulnerabilities**;**

8.20.2. Review historic audit logs to determine whether a vulnerability identified in the information system has been previously exploited**;** and

8.20.3. Correlate the output from vulnerability scanning tools to determine whether multi-vulnerability or multi-hop attack vectors are present.

8.21. Should a critical-risk or high-risk legitimate vulnerability in an information asset occur that is not amenable to timely remediation or a compensating control, the CISO may instruct the cessation of operation of the information asset until the risk is mitigated to the CISO's satisfaction.

9.0. Document Details

9.1. Initial Issue Date: March 06, 2020

9.2. Latest Revision Date: September 18, 2026

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[21]

9.6. Waiver Process: Waiver Policy[22]

9.7. Distribution: Internet[23]

10.0. Review

[20] https://www.maine.gov/oit/policies/ChangeManagementPolicy.pdf
[21] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[22] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[23] https://www.maine.gov/oit/policies-standards

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[24] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[25] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as to security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Availability: Timely and reliable access to and use of information assets.

13.2. Compensating control: An alternative mechanism instituted to mitigate a legitimate vulnerability when the mechanism to properly remediate the vulnerability is deemed impractical at present. If utilized, compensating controls must provide the same, or greater, level of defense as would be attained through the proper remediation. Compensating controls may be used until full remediation can be undertaken.

13.3. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.4. Externally hosted information asset: An information technology product consumed from the public cloud, which includes the full spectrum of Software as a Service, Platform as a Service, and Infrastructure as a Service.

13.5. Industry partner: An external party that apprises the information security division of the cybersecurity vulnerability landscape. These can be open-channel partners, such as product vendors, trade magazines, security research organizations, and so on; or they can be closed-channel partners, such as the MS-ISAC, or the MIAC.

[24] https://www.maine.gov/sos/arc/records/state/GS1Administrative.pdf
[25] https://legislature.maine.gov/statutes/1/title1sec402.html

13.6. Information asset: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.7. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.8. Legitimate vulnerability: Neither a false positive nor a false negative, but a true weakness that has been verified by a human analyst in addition to being flagged by an automated scan.

13.9. Security Operations Center: A centralized team responsible for monitoring, analyzing, and responding to cybersecurity incidents, alerts, and public disclosures.

13.10. Span of control: The area of activity and number of functions, people, or things for which an individual or organization is responsible.

13.11. Vulnerability: Weakness in an information asset that could be exploited by a threat source.

13.12. Vulnerability scanner: A specialized application custom-built to detect and report vulnerabilities. Examples include Tenable Nessus and HCL/IBM AppScan, among others.

14.0. Abbreviations

14.1. BSIMM: Building Security in Maturity Model

14.2. CISO: Chief Information Security Officer

14.3. CVE: Common Vulnerabilities and Exposures

14.4. CVSS: Common Vulnerability Scoring System

14.5. CWE: Common Weakness Enumeration

14.6. CE: Control Enhancement

14.7. DAFS: Department of Administrative and Financial Services

14.8. FOAA: [Maine] Freedom of Access Act

14.9. MIAC: Maine Information and Analysis Center

14.10. MS-ISAC: Multi-State Information Sharing & Analysis Center

14.11. NIST: National Institute of Standards and Technology

14.12. NVD: National Vulnerability Database

14.13. OIT: Office of Information Technology

14.14. OVAL: Open Vulnerability and Assessment Language

14.15. OWASP: Open Web Application Security Project

14.16. SOC: Security Operations Center